16.2.2 Example: Contractor access using verifiable credentials

To understand how ACME interprets these attributes in real-world scenarios, consider the case of a short-term contractor who needs limited, time-bounded access to audit logs. A simple set of credentials, issued by her employer and certification authority, provides exactly the context ACME needs to make an informed authorization decision.

Angela, a short-term contractor, is assigned to conduct a two-day audit of ACME's legacy Customer Collaboration platform. She is employed by AuditsRUs, a boutique security-auditing firm that ACME occasionally hires for specialized review projects. Angela also holds a CISA-R certification issued by the National Institute for Security Accreditation (NISA), a credential ACME considers authoritative for security audit qualifications.

> ***NOTE***
>
> Both the NISA and CISA-R certifications are fictional.

When Angela requests access to ACME's audit interface, her wallet creates a presentation using two credentials that state:

1. Angela is employed at AuditsRUs.
2. She holds a CISA-R certification, issued by the National Institute for Security Accreditation (NISA).

The PEP controlling access verifies that the presentation is properly signed, checks that neither credential is expired or revoked, and confirms that NISA is an issuer of security certifications that ACME has recognized for this purpose. It also verifies that the credentials were issued to Angela, the presenter. The PDP then uses the claims to evaluate policies that ensure Angela works for a firm that ACME routinely uses for audit work, and she holds the necessary certification. The policies also ensure that the requested access is within the time window specified for this engagement.